

TSEC Risk & Cyber Advisory LLC

Integrated Cybersecurity, Risk & Compliance Advisory

GUIDE-SOC2-02

SOC 2 Readiness Roadmap

A Phase-by-Phase Guide to Achieving Your First SOC 2 Report
TSEC Compliance Insights | SOC 2 Series

Document ID:	GUIDE-SOC2-02
Version:	2026 Edition
Effective Date:	June 2026
Classification:	CONFIDENTIAL
Prepared by:	TSEC Risk & Cyber Advisory LLC

TSEC Compliance Insights | TSEC Risk & Cyber Advisory LLC | www.tsecgrc.com | info@tsecgrc.com

1. Introduction: Readiness Is the Work

Organizations often discover that achieving a clean SOC 2 Type II report requires substantially more preparation than they expected. The audit is not the hardest part — implementing and consistently operating the controls being audited is. This Readiness Roadmap provides a structured, practical approach to preparing for a SOC 2 examination, from initial scoping through the final weeks before audit fieldwork begins.

2. Phase 0: Foundation (Weeks 1-4)

Define Scope and Select a CPA Firm

The first decision in any SOC 2 journey is what you're committing to examine. Scope includes: the services to be covered, the TSC categories to include, the infrastructure and systems supporting those services, and any third-party providers that are essential to service delivery (subservice organizations). Get this right early — scope changes after an examination begins are costly and disruptive.

Select your CPA firm concurrently with scope definition. Many firms will review your proposed scope and provide input before the engagement begins. Ask prospective auditors about their experience with your technology stack (cloud provider, CI/CD tools, monitoring platforms) and request references from similar-stage technology companies.

Conduct a Gap Assessment

A gap assessment maps your current state of controls against the TSC requirements. The output is a prioritized list of gaps — controls that don't yet exist, are partially implemented, or lack the documentation and evidence needed to withstand audit testing. Many organizations engage a specialist advisor (such as TSEC) for the gap assessment to benefit from experience of what auditors actually look for.

3. Phase 1: Control Implementation (Weeks 5-16)

This is the core work of SOC 2 readiness. Based on your gap assessment, you implement or strengthen controls across the key domains. The table below provides a typical prioritization framework.

Priority	Control Domain	Typical Gap	Remediation Action
High	Access Control	No formal access review process; MFA not enforced	Implement quarterly access reviews; enforce MFA across all production systems and remote access
High	Risk Assessment	No documented risk register or annual risk assessment	Complete a formal risk assessment; establish and maintain a Risk Register
High	Incident Response	No documented IR plan; no defined escalation path	Document and test an Incident Response Plan; establish an on-call rotation
High	Change Management	No code review requirement; no approval gates in CI/CD	Enforce peer review via pull requests; require approval before production deployments
Medium	Vendor Management	Vendors not tracked; no security review at onboarding	Build a Vendor Inventory; implement risk-based due diligence for new vendors

Medium	Security Awareness	No documented training; completion not tracked	Deploy annual security awareness training via an LMS; track and report completion
Medium	Vulnerability Management	No regular scanning; no remediation SLAs	Deploy automated vulnerability scanning; establish remediation timelines by severity
Lower	Logging & Monitoring	Logs not centralized; no alerting rules	Centralize logs; configure alerts for key security events

4. Phase 2: Evidence and Documentation (Weeks 12-20)

Controls are only as good as the evidence that they operated. SOC 2 auditors test operating effectiveness by reviewing evidence — screenshots, configuration exports, tickets, email approvals, meeting minutes, and system-generated reports. Building evidence collection habits during readiness, before the examination period begins, is critical to a successful audit.

4.1 Document Your Policies First

Every control needs a corresponding policy or procedure that explains how the control is supposed to work. Auditors will ask to see your policies, and evidence that controls operated according to documented procedures is stronger than evidence of ad hoc activity. At minimum, document: your Information Security Policy, Access Control Policy, Change Management Policy, Incident Response Plan, Vendor Management Policy, and Risk Assessment Methodology.

4.2 Build an Evidence Library

Create a shared folder or evidence management tool where you will store audit artifacts. Organize evidence by TSC criterion so that when the auditor requests evidence for CC6.2 (authorization of new users), you know exactly where to find access provisioning records from across the examination period. The TSEC SOC 2 Evidence Collection Guide provides a detailed inventory of the evidence types typically requested.

5. Phase 3: Internal Readiness Testing (Weeks 18-24)

Before your auditors arrive, test your own controls. Internal readiness testing simulates the audit process by reviewing evidence samples across the examination period for each key control. This exercise typically surfaces issues that would otherwise be identified by auditors as deviations — giving you time to investigate, explain, or remediate before the formal examination.

- Pull a sample of access provisioning records from the past 6 months — were they all approved before access was granted?
- Pull a sample of change management tickets — do they all have peer review and approval documented?
- Review your access review records — were reviews completed on schedule for all in-scope systems?
- Check incident log entries — were incidents classified and responded to within documented SLAs?
- Review your vendor inventory — do all in-scope vendors have current SOC 2 reports or equivalent on file?

6. Phase 4: Audit Fieldwork (Weeks 24-32 for Type I; longer for Type II)

Once the examination period begins (for Type II) or as of the examination date (for Type I), audit fieldwork commences. The auditor will request a population of evidence for each control and select a sample for testing. Your role during fieldwork is to: respond to evidence requests promptly (typically within 2-3 business days per request); provide clean, organized evidence rather than raw system exports; ensure the right personnel are available for interviews; and escalate to your engagement manager if any request is unclear or if an issue is discovered.

7. Phase 5: Report and Post-Audit Actions (Weeks 32-40)

After fieldwork, the auditor issues a draft report for management review. This is your opportunity to review the description of your system for accuracy, review the testing results, and respond to any deviations with context or management remediation plans. A final report is issued after your response is incorporated. Use the findings from the examination to drive your remediation roadmap for the next examination period.

8. Readiness Timeline at a Glance

Phase	Weeks	Key Deliverables
Phase 0: Foundation	1-4	Scope defined; CPA firm selected; gap assessment complete
Phase 1: Control Implementation	5-16	Priority controls implemented and documented
Phase 2: Evidence & Documentation	12-20	Policies documented; evidence library established
Phase 3: Internal Readiness Testing	18-24	Internal control testing complete; gaps remediated
Phase 4: Audit Fieldwork	24-32+	Evidence requests responded to; interviews conducted
Phase 5: Report & Post-Audit	32-40	Draft report reviewed; final report issued; remediation planned

9. Key Success Factors

- Executive sponsorship: SOC 2 readiness requires cross-functional work across engineering, IT, HR, and legal — without leadership support, it stalls
- Start early: organizations consistently underestimate the time required; 6-9 months of readiness before a Type II examination is common
- Treat evidence collection as a habit, not an annual event: controls need to operate consistently all year, not just when the auditor asks
- Don't hide deviations: when internal testing surfaces exceptions, investigate the root cause and fix the process — don't just explain away the instance
- Allocate a dedicated project owner: SOC 2 readiness is a project that needs someone accountable for driving it to completion

10. Tools and Technology That Support SOC 2 Readiness

A growing ecosystem of compliance automation tools has emerged specifically to support SOC 2 readiness. These platforms help with evidence collection, policy management, vendor tracking, and audit collaboration. The right tool can significantly reduce the administrative burden of SOC 2 preparation — but no tool eliminates the need to actually implement controls.

Tool Category	What It Does	SOC 2 Use Case
Compliance Automation Platforms	Automate evidence collection by integrating with cloud providers, HR systems, ticketing systems, and identity providers to pull audit evidence automatically	Reduces manual evidence collection; maintains a continuously updated audit-ready evidence library
Policy Management Tools	Version-controlled policy libraries with acknowledgment tracking	Ensures policies are current, approved, and acknowledged by all Workforce members
Vendor Risk Management Platforms	Track vendor inventory, due diligence status, and third-party audit reports	Supports CC9.2 vendor management requirements
SIEM / Security Monitoring	Centralize and analyze security event logs	Provides evidence of CC7.1 and CC7.2 monitoring controls
Identity Governance Platforms	Automate access provisioning, reviews, and deprovisioning workflows	Provides clean, system-generated evidence for CC6 access control requirements

11. Managing Deviations During Audit Fieldwork

Even well-prepared organizations encounter deviations during audit fieldwork — instances where a control did not operate exactly as described for a particular tested sample. How you handle deviations matters as much as whether they occur.

When a deviation is identified, the auditor will typically ask for a management response addressing: the nature of the deviation; whether it was isolated or systemic; the root cause; and the remediation action taken or planned. A thoughtful, honest management response that demonstrates root cause understanding and concrete remediation is far more credible than a defensive response or a claim that the deviation is immaterial.

Certain types of deviations carry more weight with customers than others. A missing approval on a change management ticket in Month 3 of a 12-month period is less concerning than a repeated pattern of access being provisioned before approval was obtained. Context and proportionality matter when customers review deviations.

12. After Your First SOC 2: Maintaining the Program

Many organizations achieve their first SOC 2 report and then find that maintaining compliance — consistently operating controls over a full annual examination period — is the harder challenge. Lessons from organizations that sustain effective SOC 2 programs year over year:

- Automate evidence collection where possible: manual evidence collection doesn't scale as the organization grows. Invest in tooling that captures evidence continuously.
- Treat SOC 2 controls as operational requirements, not compliance theater: access reviews, change management approvals, and incident documentation should be part of how the engineering and IT teams operate by default, not special activities done for auditors.

- Manage scope carefully as the organization grows: new systems, new cloud providers, and new products may bring new systems into scope. Stay ahead of scope changes by reviewing them through the lens of SOC 2 impact before they happen.
- Use deviations as continuous improvement signals: every deviation the auditor identifies is evidence of a process or control that needs strengthening. Track deviations and remediation as a metric.
- Engage your auditor year-round: don't treat your CPA firm as a once-a-year visitor. Brief them on significant changes, ask for pre-audit guidance on new control areas, and use their expertise to avoid surprises during fieldwork.